

Role-Based Access Control (RBAC) Model

System Authorization & Boundary Specification

1. Purpose

The RBAC model defines the roles, permissions, and access boundaries for the Smart Asset Inventory & Predictive Maintenance system.

Authorization is determined by both:

- **Role:** What the user is allowed to do.
- **Organizational Scope:** Where the user is allowed to perform the action.

2. Roles

The system contains five primary roles:

- Asset Administrator
- Procurement / Finance Viewer
- Custodian / Department Manager
- Maintenance Technician
- Auditor

3. Role Responsibilities

Asset Administrator Responsible for managing the asset registry and asset lifecycle. Permissions: • Create and update assets Import assets Manage locations and asset categories • View asset information Transfer assets Manage custody assignments • Retire assets according to the retirement workflow View procurement references • View maintenance records View audit/history information <i>Note: Does not automatically have permission to modify financial/procurement records unless explicitly granted.</i>	
Procurement / Finance Viewer Responsible for procurement and financial information. Permissions: • View basic asset information • Create and update suppliers • Create and update purchase orders • Create and update invoice/receipt metadata • Manage warranty information • View asset cost/value • View procurement references & attachments	Restrictions: • Cannot transfer assets • Cannot change asset custody • Cannot modify maintenance records • Cannot retire assets • Cannot modify general asset registry data unless explicitly granted
Custodian / Department Manager Responsible for assets assigned to their organizational scope. Permissions: • View assets within assigned scope • View relevant asset information • Confirm asset assignment & custody • Report/update asset condition • View maintenance status	Restrictions: • Cannot access invoices or financial costs • Cannot modify supplier or PO info • Cannot perform asset retirement • Cannot transfer assets unless authorized • Cannot access assets outside scope

Maintenance Technician

Responsible for maintenance operations.

Permissions:

- View assets required for maintenance
- View assigned/due work orders
- Update work orders & record service activities
- Record parts used & maintenance cost
- Record downtime, completion, & outcome
- View maintenance history

Restrictions:

- Cannot access financial documents (invoices)
- Cannot modify general asset registry info
- Cannot transfer assets
- Cannot retire assets

Auditor

Responsible for reviewing system information and audit evidence.

Permissions:

- Read asset inventory & asset history
- Read custody and transfer history
- Read maintenance history & financial refs
- Read exceptions & audit logs

Restrictions:

- Read-only role
- Cannot create/modify/transfer/retire assets
- Cannot modify work orders or audit records

4. RBAC Permission Matrix

Resource / Action	Asset Admin	Procurement / Finance	Custodian / Manager	Maintenance Tech	Auditor
Asset basic data	RW	R	R	R	R
Asset serial / specifications	RW	R	R	R	R
Asset location	RW	R	R	R	R
Asset custodian	RW	R	Confirm	R	R
Asset condition	RW	R	Update	Update	R
Supplier	RW	RW	R	R	R
Purchase Order	R	RW	R	✗	R
Invoice / Receipt	R	RW	✗	✗	R
Warranty	R	RW	R	R	R
Asset cost / value	R	RW	✗	✗	R
Asset transfer	RW	✗	Request / Confirm	✗	R
Maintenance Template	RW	✗	R	R	R
Work Orders	RW	R	R	RW	R
Service Records	R	R	R	RW	R
Parts / Maintenance Cost	R	R	✗	RW	R
Downtime	R	✗	R	RW	R
Retirement	RW	✗	Request	✗	R
Audit / History	R	R	R*	R*	R
User / Role Management	RW	✗	✗	✗	✗

Legend: R = Read | W = Create / Update | RW = Read + Create / Update | ✗ = No access

6. Authorization Rules

- Authentication is required before accessing protected resources.
- Every protected API operation must perform backend authorization.
- Having a role does not automatically grant access to all organizational units.
- Users can perform only actions permitted by their role.
- Users can access only resources within their authorized organizational scope.
- Resource-level authorization must be applied to individual assets, invoices, work orders, documents, and other protected resources.
- Frontend restrictions shall not be considered an authorization control.
- Users cannot modify their own roles or organizational scopes.
- Retirement, transfer, and other critical lifecycle actions must be restricted to authorized roles.
- Audit and history records must remain protected from unauthorized modification or deletion.

7. Authorization Decision

User → Authenticated? → Role → Required Permission → Organizational Scope → Resource Ownership / Scope → ALLOW / DENY

Example 1 (ALLOW):

Custodian → ASSET_READ → Computer Science Scope → Asset belongs to Computer Science → **ALLOW**

Example 2 (DENY):

Custodian → ASSET_READ → Computer Science Scope → Asset belongs to Engineering → **DENY**

8. Security Boundary

The RBAC model protects the following major resources:

Asset Registry • Asset Locations • Custody and Transfer Records • Procurement References • Invoices and Receipts • Warranty Information • Maintenance Templates • Work Orders • Service Records • Retirement Records • Audit and History Records

9. Permission Code Definitions

The permissions table stores string codes (`permissions.code`) referenced by `role_permissions` during backend authorization:

Permission Code (permissions.code)	Resource / Action (resource_type : action)
assets:read	assets : read
assets:write	assets : create / update
assets:import	assets : bulk import
assets:retire	asset_retirements : create / approve
assets:transfer	custody_transfers : create / approve
custody:confirm	asset_assignments : confirm (Custodian workflow)
suppliers:write	suppliers : create / update
purchase_orders:write	purchase_orders : create / update
invoices:read	invoices : read
invoices:write	invoices : create / update
warranties:write	warranties : create / update
financial:read	invoices, purchase_orders, asset cost : read
work_orders:read	work_orders : read
work_orders:update	work_orders : update / complete
service_events:write	service_events, work_order_parts : create